

3.6.3 Business Priority	3.6.3 Relevant quote from casefile
Exceptional patient care	I thought it was VERY clear what our business priorities here at Rigel are: - exceptional patient care
innovative software development for delivering that exceptional patient care	I thought it was VERY clear what our business priorities here at Rigel are: - innovative software development for delivering that exceptional patient care
impeccable protection of customer privacy	I thought it was VERY clear what our business priorities here at Rigel are: - impeccable protection of customer privacy

3.6.3 CSF Phase	3.6.3 CSF Phase Sub-category	3.6.3 Problem name	3.6.3 Description	3.6.3 Relevant quotes from casefile	3.6.3 Relevance to RCI's priorities	3.6.4 Root cause	3.6.5 Problem ID
1 Identify	Identify · Asset inventory	Patient Records Compromised	The patient data server has been attacked with ransomware	"Bad news. The patient data server is going to be offline for the foreseeable future. It has been encrypted with ransomware." "[Email 1.3]"		No Cybersecurity awareness	1.1
2 Protect	Protect · Security awareness	No security awareness among employees	The employee opened a phishing email which looked like a patients record but were filled with ransomware	"We are still figuring out which attachment she (Records-013 user = Asma Zarif) opened. - Running hypothesis: The attacker probably sent her some bogus patient records and that's how her workstation got infected. - We've pulled the workstation for forensic examination to identify the malicious attachment." "[Email 6.2]"		No policies requiring employee to undergo cybersecurity awareness training	2.1
3 Detect	Detect · Continuous monitoring (SIEM)	Outdated SIEM system	no continuous monitoring thus falling to the victim of ransomware	"Yeah...I'm sure. There's a physical label that says "EHR-14" on the device, and when I look in Wireshark, all the workstations are trying to connect to ehr-14.rigelcyberinstitute.local. EHR-14 is definitely the patient records server. And it is definitely infected with WannaCry. p.s. Kinda wishing we'd made tuning the SIEM a higher priority...right around...now..." "[Email 2.4]"		No SOC teams in place	3.1
4 Respond	Respond · IRPs	IRP not kept upto dated	IRP was last updated 2 years ago	"Apparently Sean updated it two years ago" "[Email 2.4]"		No Incident-response plan or process.	4.1

3.6.5 Root cause	3.6.5 Problem ID	3.6.6 Solution(s)
No Cybersecurity awareness	1.1	Implement Cyber Security Awareness training every 6 months or when systems are updated.
No policies requiring employee to undergo cybersecurity awareness training	2.1	Create policies requiring employees to finish CyberSecurity awareness training as part of the onboarding process.
No SOC teams in place	3.1	SOC teams should be part of the organization where they will be updating SIEMS and implement continuous monitoring.
No Incident-response plan or process.	4.1	Incident Response Team should be hired to create/plan/implement/process incident response plan.

3.6.7 Order (Priority)	3.6.8 Solution	3.6.8 Problem	3.6.8 Prevented Problems	3.6.8 Relevance
1	SOC teams should be part of the organization where they will be updating SIEMS and implement continuous monitoring. Implementing an SOC team would make sure to prioritize SIEM.	No SOC teams in place. Every organization needs SIEM. Missing this part from an organization can impact drastic challenges and even risky situations.	RCI has fallen victim to ransomware resulting in loss of important patient records which they had no backup for. If there was an SOC team in place who were monitoring continuously, this wouldn't have happened as their main job is to be cautious of any virus or hacker hacking into the system.	One of the key priorities of RCI is "impeccable protection of customer privacy". The solution to this specific problem will do exactly that. When there is a SOC in place in the company, there is continuous monitoring and a security system who are there to pick up when things go left.
2	Create policies requiring employees to finish CyberSecurity awareness training as part of the onboarding process. This will prepare the employees by giving them an understanding on how to spot phishing emails and external scam links.	No policies requiring employee to undergo cybersecurity awareness training. Which means employees aren't trained on when to spot phishing emails or possible scams.	RCI have lost all of their last 8 months of important patient records because of opening a phishing email. This clearly demonstrated that they employee had no idea whether email was real or fake. If all of the employees of RCI had gotten through a cybersecurity awareness training then this wouldn't have happened.	Another one of the key priorities of RCI is "exceptional patient care". When the attacker attacked the patient data server comprising the important patient records, it resulted in not being able to care for patients since they lost all the information about their patients. Since, now the information is not available, services cannot be provided to the patients. So to provide, exceptional patient care, we have to make sure everything else is on point and secured, whether that's through cybersecurity awareness or exceptional physical service.
3	Incident Response Team should be hired to create/plan/implement/process incident response plan. If things fall out of plan and system gets compromised, there needs to be a backup solution. In this case, it is the IRT. IRT create, plan and implement incident response plans. By having an IRT in the organization, they can always rely on them to fully back up if anything goes wrong.	The IRP was updated 2 years ago. Time changes as well as circumstances. An Incident Response Plan which was created 2 years ago for that specific time frame, it will not work today. IRP needs to be updated every now and then based on changes of system or updates to the system.	If there was an IRT in place on RCI, then there would be a recently updated IRP which could recover the data that was stolen by the attacker. No services would need to be stopped and no server would be compromised for a long period of time.	Lastly the other one of the key priorities of RCI is - "innovative software development for delivering that exceptional patient care". Not having an Incident Response Plan sounds like something that goes directly against the priority listed. Having an innovative software development doesn't just mean the "software" it's also anything and everything that is related to software and has importance in the system. Having an outdated IRP is no benefit because situations change and while 2 years may not sound like a long time, it is when it comes to company infrastructure and software. So having everything up to date is a necessary move.

3.6.7 Order (Priority)	3.6.8 Solution	3.6.8 Problem	3.6.8 Prevented Problems	3.6.8 Relevance
4	Implement Cyber Security Awareness training every 6 months or when systems are updated. Just by implementing this simple step, it will bring down further cases like the one that happened recently.	The employee opened a phishing email which looked like a patients record but were filled with ransomware. if she had any training on how to spot phisihing emails or scam links, this casualty wouldn't have happened.	by implementing this simple solution, RCI could have saved tons of money. Currently RCI is spending money to the ransomware to get its patient records back. If the employee who opened the phishing email were properly trained on cybersecurity awareness. No phishing attempt would have been successful.	This solution is also relevant to the "exceptional patient care". Since, the data were lost during the phishing attack, all services needed to be stopped due to lack of infromatoin of the patients. if this wouldn't have happened RCI would smoothly operate just as they did until recently.